# 메인블로그 요구사항 분석서

세부 정책과 결정 기록 (6장, 8장)

2026-10-02

**목차** (제목을 누르면 그 위치로 이동합니다)

- 6. 세부 정책
  - 6.1 검색
  - 6.2 SNS 공유
  - 6.3 파일 업로드
  - 6.4 태그
  - 6.5 중복 규칙
  - 6.6 글·댓글 상세
  - 6.7 회원·보안·운영 숫자
- 8. 결정 기록

## 6. 세부 정책

기능 요구사항을 코드로 옮길 때 필요한 숫자와 규칙입니다. 상태가 확정인 항목은 그대로 구현하고, 보류인 항목은 팀에서 더 정해야 합니다. 팀에서 정한 것은 상태를 **확정**으로 바꾸고, 추천안과 다르게 정한 것은 추천안 칸을 고쳐 주세요.

### 6.1 검색

| 항목 | 추천안 | 이유 | 상태 |
|---|---|---|---|
| 검색어 길이 | 2~20자 | ngram이 2글자 단위라 1글자는 검색이 안 됨 | 확정 |
| 정렬 | 관련도순(기본), 최신순, 인기순 / 분류바(관련도, 최신, 인기) | 검색은 관련도가 기본이고, 최신순은 선택 | 확정 |
| 결과에서 제외 | 비공개 블로그(공백으로 표시), 숨김·삭제 글, 내가 차단한 회원의 글 | 검색으로 비공개 내용이 새지 않게 | 확정 |
| 부가 기능 | 1차: 최근 검색어(본인만, 최대 10개, x 개별삭제 전체 삭제 기능) | 자동완성은 검색 로그 저장과 집계가 따로 필요 | 확정 |

### 6.2 SNS 공유

| 항목 | 추천안 | 이유 | 상태 |
|---|---|---|---|
| 공유 수단 | 1차: 링크 복사. 2차: 카카오톡, X, 페이스북, 인스타, 텔레그램 | 링크 복사는 바로 되고, 카카오톡은 앱 키 등록이 필요 | 확정 |
| 카카오톡 | Kakao JavaScript SDK로 공유 버튼 구현 | 국내 사용자가 가장 많이 쓰는 공유 경로 | 확정 |
| 미리보기 | 글 페이지에 Open Graph 태그(`og:title`, `og:description`, `og:image`)<br>url 최상단, 제목 상단후 닉네임까지, 이미지중단 | 없으면 카톡·X에서 제목과 썸네일이 안 뜸 | 확정 |

| 항목 | 추천안 | 이유 | 상태 |
|---|---|---|---|
| 공유 수 집계 | 하지 않음 | 외부에서 실제로 공유됐는지는 알 수 없음 | 확정 |

## 6.3 파일 업로드

| 항목 | 추천안 | 이유 | 상태 |
|---|---|---|---|
| 허용 형식 | jpg, jpeg, png, gif, webp | 블로그에 필요한 사진 형식은 이것으로 충분 | 확정 |
| 제외 형식 | svg, 동영상, 문서(pdf, hwp 등), 압축 파일 | svg는 파일 안에 스크립트를 넣을 수 있어 XSS 위험 | 확정 |
| 글 이미지 크기 | 장당 3MB | 휴대폰 원본 사진(3~5MB)이 그대로 올라감. 지금 프로젝트 설정도 5MB | 확정 |
| 글 이미지 개수 | 글 하나에 최대 10장 (한 번에 보내는 용량 최대 10MB) | 서버 저장 공간과 업로드 시간 제한 | 확정 |
| 프로필·블로그 대표 이미지 | 3MB, 1장 | 작게 표시되는 이미지라 큰 파일이 필요 없음 | 확정 |
| 검증 방법 | 확장자, MIME 타입(jpg, png, webp,gif,jpeg), 파일 시그니처(파일 앞부분 바이트)를 모두 확인 | 확장자만 바꾼 실행 파일을 막기 위해 (SEC-08) | 확정 |
| 저장 방식 | 서버에는 UUID 이름으로 저장, 원래 이름은 DB에만 | 파일 이름 충돌과 경로 조작 공격 방지 | 확정 |
| 위치 정보 | 업로드할 때 EXIF(GPS 등) 제거 | 사진에 집 위치가 남아 있을 수 있음 | 확정 |
| 썸네일 | 목록용 썸네일을 따로 만들지 않고 원본을 CSS로 줄여 표시 (1차) (마우스 포인터를 글제목에 올렸을때 사진이 보이게) | 구현이 간단함. 느리면 2차에 추가 | 확정 |
| 글 삭제 시 | 글을 정말 삭제하시겠습니까 확인버튼 | | 확정 |

## 6.4 태그

| 항목 | 추천안 | 이유 | 상태 |
|---|---|---|---|
| 개수 | 글 하나에 최대 10개 | 태그 도배로 검색 결과가 오염되는 것 방지 | 확정 |
| 길이 | 1~20자 | DB 컬럼 크기(30자) 안에서 여유 | 확정 |
| 허용 문자 | 한글, 영문, 숫자, `_` | 특수문자·공백이 있으면 태그 링크가 깨짐 | 확정 |
| 입력 정리 | 앞의 `#`과 앞뒤 공백 자동 제거, 가운데 공백은 `_`로 바꿈 | 사용자가 `#`맛집처럼 입력해도 같은 태그가 되게 | 확정 |
| 중복 (한 글 안) | 같은 태그를 여러 번 넣으면 하나로 합침 | DB의 `uk_post_tags`가 중복을 막음 | 확정 |
| 중복 (대소문자) | 영문은 소문자로 저장 (`Java` = `java`) | 같은 태그가 두 개로 나뉘는 것 방지 | 확정 |

## 6.5 중복 규칙

| 대상 | 추천안 | 이유 | 상태 |
|---|---|---|---|
| 이메일 | 중복 불가. 소문자로 바꿔 저장 | `A@x.com`과 `a@x.com`은 같은 메일함 | 확정 |
| 닉네임 | 중복 불가. 2~12자, 한글·영문·숫자 | 프로필 주소와 멘션에 쓰임 | 확정 |
| 닉네임 예약어 | 관리자, `admin`, 운영자, 탈퇴한 회원 사용 불가 | 관리자 사칭 방지 | 확정 |

| 대상 | 추천안 | 이유 | 상태 |
|---|---|---|---|
| 블로그 주소 | 중복 불가. 영문 소문자·숫자·`-` 로 3~30자 | URL에 들어가는 값 | 확정 |
| 블로그 주소 예약어 | `main`, `admin`, `api`, `login`, `signup`, `search` 등 사용 불가 | 사이트 주소와 겹치면 페이지가 안 열림 | 확정 |
| 블로그 이름 | 중복 허용 | 블로그는 주소로 구분하므로 이름이 같아도 됨 | 확정 |
| 탈퇴 후 재가입 | 같은 이메일로 바로 재가입 가능, 예전 글과는 연결 안 됨 | 탈퇴 시 이메일을 비우므로(DB 설계) | 확정 |
| 좋아요·팔로우·구독 | 한 번만. 다시 누르면 취소(트래픽 제한 걸기) | DB UNIQUE가 중복을 막음 | 확정 |
| 신고 | 같은 대상은 한 사람이 한 번만(2주뒤 신고가능) | 한 사람이 신고를 부풀리는 것 방지 | 확정 |
| 참여 신청 | 대기 중인 신청이 있으면 다시 신청 불가. 거절되면 7일 뒤 재신청 | 블로그장에게 같은 신청이 쌓이는 것 방지 | 확정 |

## 6.6 글·댓글 상세

| 항목 | 추천안 | 이유 | 상태 |
|---|---|---|---|
| 페이징 기본값 | 10개 | 처음 들어왔을 때 보여줄 개수 | 확정 |
| 제목 | 1~30자 | 목록 한 줄에 표시 | 확정 |
| 본문 | 최대 5,000자 (공백·마크다운 기호 포함). DB는 TEXT, 글자 수는 서버에서 검사 | 보통 블로그 글(1,000~3,000자)이 여유 있게 들어가고, 도배는 막음 (D-92) | 확정 |
| 에디터 | 마크다운 (저장은 마크다운, 표시할 때 HTML로 바꾼 뒤 위험한 태그 제거) | WYSIWYG보다 XSS 막기가 쉽고, 구현이 가벼움 (SEC-06) | 확정 |
| 수정 표시 | 수정한 글과 댓글에 "수정됨" 표시 댓글만 | 댓글이 달린 뒤 내용이 바뀜 수 있음 | 확정 |
| 임시저장 | 1차에는 브라우저에만 자동 저장 | DB 없이 글 쓰다 날리는 것을 막음 | 확정 |
| 댓글 길이 | 1~500자 | DB 컬럼 크기와 맞춤 | 확정 |
| 대댓글 깊이 | 1단계까지 (대댓글에는 답글 불가) 태그식으로 구현가능하면 해보기 | 화면이 오른쪽으로 계속 밀리지 않게 | 확정 |
| 댓글 삭제 | 답글이 있으면 "삭제된 댓글입니다"로 표시하고 답글은 남김 | 답글의 맥락이 사라지지 않게 | 확정 |

## 6.7 회원·보안·운영 숫자

| 항목 | 추천안 | 이유 | 상태 |
|---|---|---|---|
| 비밀번호 | 8~15자, 영문·숫자·특수문자를 모두 포함 대소문자 구분 | SEC-02를 숫자로 확정 | 확정 |
| 로그인 잠금 | 5회 연속 실패 시 5분 잠금 또는 매크로 방지 기능 추가 생각 | 비밀번호 대입 공격을 늦춤 (SEC-03) | 확정 |
| 사람 확인 (CAPTCHA) | 로그인 3회 실패 후에 표시 | 모든 화면에 띄우면 불편하므로 봇이 노리는 곳에만 | 확정 |
| 로그인 유지 | "로그인 유지" 체크박스. 체크 안 하면 브라우저를 닫거나 30분 활동이 없으면 로그아웃, 체크하면 14일 유지. 로그아웃 시 쿠키 삭제 (JWT, SEC-04) | 공용 PC에서 로그인이 남는 것 방지 (SEC-04) | 확정 |

| 항목 | 추천안 | 이유 | 상태 |
|---|---|---|---|
| 비밀번호 재설정 인증번호 | 30분 뒤 만료, 1회용, 5번 틀리면 무효 | 메일이 유출돼도 쓸 수 있는 시간을 짧게 (SEC-05) | 확정 |
| 조회수 | 비회원 회원 블로그장 블로그 글을 들어갈 시 카운트<br>같은 사람이 같은 날 같은 글을 보면 1번만 셈 | 새로고침이나 봇으로 조회수를 부풀리는 것 방지 | 확정 |
| 알림 보관 | 무슨 알림을 받을지 설정하는 체크박스 설정<br>회원, 블로그장 7일 또는 일괄 삭제 설정가능하게 | 알림 테이블이 계속 커지는 것 방지 | 확정 |
| DB 백업 | 매일 03:00 전체 백업, 7일치 보관, 서버 밖 저장소에 복사 | DB가 망가져도 하루 전 데이터로 되살림 (OPS-01, D-101) | 확정 |
| 서버 로그 보관 | 30일 뒤 자동 삭제. 비밀번호·토큰·인증번호는 남기지 않음 | 오류·공격 확인에 충분하고 삭제 데이터 보관 기간과 같음 (OPS-03, D-103) | 확정 |
| 메일 발송 실패 | 다시 시도 안내, 자동 재발송 없음, 실패한 인증번호는 무효이고 1분 재발송 제한에 세지 않음 | 1차 규모에 맞게 단순하게 (OPS-07, D-107) | 확정 |
| 라이브러리 업데이트 확인 | 매주 월요일 Dependabot이 업데이트 PR을 엶. 자동 merge 없음 | 보안 구멍이 알려진 라이브러리를 오래 쓰지 않게 (OPS-10, D-110) | 확정 |

## 8. 결정 기록

팀에서 정하거나 바꾼 내용을 이유와 함께 남깁니다. 앞으로 결정하거나 바꿀 때마다 이 표에 한 줄씩 추가하고, 바꾼 경우에는 이전 내용과 바꾼 이유를 함께 적습니다. 최신 결정이 위입니다.

| 번호 | 날짜 | 결정 (관련 항목) | 이유 | 이전 내용 → 바꾼 이유 |
|---|---|---|---|---|
| D-117 | 2026-10-12 | 화면 디자인을 "정돈된 목록형"(흰 바탕, 회색 구분선, 포인트 빨강 #f04452, 목록 중심)으로 바꿈. 서버는 바꾸지 않고 CSS·JS만 고침. 밝은 모드와 어두운 모드를 두고, 처음에는 기기 설정을 따르며 상단 메뉴의 버튼으로 바꾸면 그 브라우저에 기억함(로그인과 무관) (4.2 성능·사용성) | JJ가 여러 시안 중 정돈된 목록형을 고르고 다크/화이트 모드를 요청함 | 새로 정함 → JJ가 고름 |

| 번호 | 날짜 | 결정 (관련 항목) | 이유 | 이전 내용 → 바꾼 이유 |
|---|---|---|---|---|
| D-116 | 2026-10-12 | 블로그마다 움직이는 픽셀 그림(동물이나 물건) 마스코트 하나를 보여 줌. 미리 그린 18종, 동물 10종(bear 곰, cat 고양이, dog 강아지, rabbit 토끼, fox 여우, penguin 펭귄, bird 새, frog 개구리, hamster 햄스터, owl 부엉이)과 물건 8종(computer 컴퓨터, camera 카메라, book 책, plane 비행기, headphones 헤드폰, gamepad 게임기, coffee 커피, cake 케이크) 중 하나를, 블로그를 만들 때와 블로그 정보(이름·태그)를 고칠 때 서버가 블로그 이름과 태그만 Claude API에 보내 고르게 함(소개·글 내용은 보내지 않음). 블로그의 주제가 물건과 뚜렷하게 맞으면 물건(예: 개발 → 컴퓨터, 사진 → 카메라, 독서 → 책), 아니면 동물을 고름. 블로그 저장은 고르기를 기다리지 않고, 저장한 뒤 따로 고름. API 키가 없거나 호출이 실패하거나 목록에 없는 답이 오면 태그 단어 사전으로 고르고, 맞는 단어가 없으면 이름으로 정해지는 기본값을 씀. 결과는 `blogs.mascot`에 저장하고, NULL이면 아직 안 고른 상태라 화면은 기본 그림을 보여 줌. 마스코트가 없는 기존 블로그는 서버가 조금씩 채움. 그림은 블로그 첫 화면 제목 옆에 크게, 블로그 카드 이름 앞에 작게 보여 줌 (BLG-14, blogs.mascot) | JJ가 "AI가 고르기"를 고름. 그림 품질은 미리 그린 것으로 보장하고, 사전에 없는 태그도 AI가 알맞게 고름. AI가 그림을 직접 그리는 방식은 품질이 들쭉날쭉해서 뺌. JJ가 개발 블로그에는 컴퓨터처럼 태그에 맞는 물건도 넣자고 함 | 새로 정함 → JJ가 고름 |
| D-115 | 2026-10-08 | 블로그장이 계정 정지 중이고 부블로그장이 없으면 정지 동안 그 블로그의 참여 신청(자유 참여·승인제 모두)을 일시 중지하고, 신청 화면에 "블로그장 정지로 참여 신청이 일시 중지되었어요 (끝나는 날짜까지)"를 띄움. 이미 들어온 대기 중 신청은 그대로 두고 정지가 끝나면 블로그장이 처리. 신고 처리는 D-100대로 메인 관리자 (ADM-08, BLG-04) | 승인할 사람이 없는 동안 신청이 쌓이거나 관리 없이 멤버가 늘지 않게 하고, 신청자에게 이유를 알림 | 정해지지 않음 → 팀이 정함 |
| D-114 | 2026-10-08 | 블로그장이 계정 정지 중이고 부블로그장이 있으면, 정지 동안 모든 부블로그장이 받은 체크박스와 관계없이 멤버 관리 권한(참여 신청 승인, 멤버 경고·정지·강제 퇴장, 블로그 안 신고 처리)을 임시로 가짐. 블로그장 본인과 블로그장이 쓴 글·댓글 신고는 계속 메인 관리자가 처리하고, 위임·폐쇄·부블로그장 지정과 권한 변경은 블로그장만 할 수 있음. 부블로그장이 없으면 D-100대로 메인 관리자가 처리. 정지가 끝나거나 해제되면 임시 권한은 바로 원래 체크박스대로 돌아가고, 남은 신고는 블로그장이 이어서 처리 (ADM-08, BLG-13) | 블로그 사정을 아는 사람이 바로 처리해 참여 신청과 신고가 쌓이지 않고 메인 관리자 부담이 줄어듦. 임시 권한은 따로 저장하지 않고 정지 여부로 계산해 되돌릴 일이 없음 | D-100(정지 중 신고는 메인 관리자) → 팀이 변경 |
| D-113 | 2026-10-08 | 이메일·전화번호는 1차에 DB에 암호화하지 않고 평문으로 저장한다. 대신 HTTPS(SEC-10), 화면·응답·로그에서 가리기(4.4, OPS-03), 백업은 운영자만(OPS-01), DB는 서버만 접속, 탈퇴 30일 뒤 삭제(4.5)로 보호한다. 2차에 할 수 있으면 로그인에 쓰지 않는 전화번호부터 암호화(AES-GCM + 찾기용 해시 칸)를 검토한다 (4.6) | 개인정보보호법에서 저장 암호화가 의무인 것은 비밀번호·고유식별정보·생체정보이고 이메일·전화번호는 아님. 이메일은 로그인·중복 가입 확인에 그대로 찾아야 해서 암호화하면 검색용 해시 칸과 키 관리가 더 필요함 | 저장 암호화 여부가 정해져 있지 않았음 → 팀이 2차로 미룸 |

| 번호 | 날짜 | 결정 (관련 항목) | 이유 | 이전 내용 → 바꾼 이유 |
|---|---|---|---|---|
| D-112 | 2026-10-07 | API 문서는 springdoc-openapi로 코드에서 자동으로 만든다. local 프로필에서만 Swagger 화면(`/swagger-ui.html`)과 OpenAPI 명세(`/v3/api-docs`)를 열고, prod와 프로필을 정하지 않았을 때는 꺼서 두 주소가 404를 돌려준다. `specs/001-main-blog/contracts/`의 API 명세는 local에서 받은 `/v3/api-docs`로 만든다 (OPS-12) | 화면을 만드는 사람이 API 주소와 요청·응답 형식을 바로 보고 눌러 볼 수 있음. 코드에서 만들어 문서와 실제 API가 어긋나지 않음. 운영에 열어 두면 공격자에게 모든 API 목록을 알려주게 되어 닫음 | API 명세(contracts/)를 손으로 정리할 계획만 있었음 → 시스템 요구사항 검토에서 자동 생성으로 정함 |
| D-111 | 2026-10-07 | 실행 환경을 local(개발자 컴퓨터)과 prod(운영 서버) 두 프로필로 나눈다(테스트는 test). 공통 설정은 `application.yml`에 운영 기준으로 안전하게 두고 local에서만 푼다(Secure 없는 쿠키로 http://localhost에서 동작, Swagger 열기, SQL 로그). 비밀값(JWT 비밀키, DB 비밀번호, Gmail 앱 비밀번호, Turnstile 비밀키)은 환경변수로만 받고 저장소에 올리지 않는다. prod에서는 비밀값이 비었거나 예시 값(`.env.example`)이면 서버가 뜨지 않고, 로그인 쿠키에 Secure를 붙이며 http 요청은 https로 돌려보낸다 (OPS-11, SEC-04, SEC-10) | 로컬 편의 설정(Swagger, Secure 없는 쿠키)이 운영에 그대로 나가는 실수를 막음. 비밀키를 빠뜨리거나 예시 값으로 운영 서버가 뜨면 누구나 아는 키로 로그인 토큰을 위조할 수 있어 아예 뜨지 않게 함. 기본값이 안전하면 프로필을 빠뜨려도 운영이 위험해지지 않음 | 환경별 설정이 따로 없었음 → 시스템 요구사항 검토에서 추가 |
| D-110 | 2026-10-07 | GitHub Dependabot이 매주 월요일 라이브러리(Gradle)와 GitHub Actions의 새 버전을 확인해 업데이트 PR을 연다. 저장소 설정에서 보안 취약점 알림(Dependabot alerts)과 보안 업데이트 PR도 켠다. 업데이트 PR도 자동 빌드·테스트(OPS-05)를 통과해야 merge하고, 자동으로 merge하지 않는다. 보안 업데이트를 먼저 확인하고, 큰 버전 업데이트(예: Spring Boot 4 → 5)는 팀이 따로 정한다 (OPS-10) | 쓰는 라이브러리(Spring, jjwt, jsoup 등)에 보안 구멍이 알려져도 사람이 알아채기 어려움. 매주 PR로 받으면 조금씩 올릴 수 있고 깨지는지 CI에서 바로 보임. GitHub 기본 기능이라 비용과 설치가 없음 | 라이브러리 보안을 확인하는 방법이 없었음 → 시스템 요구사항 검토에서 추가 |
| D-109 | 2026-10-07 | 중요한 규칙은 자동 테스트로 확인한다. 대상은 성공 기준 SC-002(블로그별 권한), SC-003(가입 여부 숨김), SC-004(개인정보 가리기), SC-005(04:00 배치), SC-006(블로그 수 동시 제한), SC-007(조회수), SC-009(오류 응답), SC-011(운영 설정)이다. DB를 쓰는 테스트는 H2 같은 대체 DB가 아니라 Testcontainers로 띄운 실제 MySQL 8에서 운영과 같은 Flyway 파일로 만든 스키마로 돌린다. 테스트는 PR마다 자동 빌드(OPS-05)에서 돌고, 테스트를 끄거나 건너뛰어 통과시키지 않는다. SC-001(속도), SC-008(서버 2대), SC-010(백업 복구)은 사람이 확인한다 (OPS-09) | FULLTEXT ngram 검색, 동시 생성 때 행 잠금, ENUM 같은 동작은 MySQL에서만 같게 나와 대체 DB로는 통과해도 운영에서 깨질 수 있음. 손으로 매번 확인하기 어려운 권한·동시성 규칙을 코드가 바뀔 때마다 확인함 | plan.md에 권한(SEC-07)과 04:00 배치만 통합 테스트로 확인한다고 있었음 → 시스템 요구사항 검토에서 대상과 테스트 DB를 정함 |
| D-108 | 2026-10-07 | DB 구조는 Flyway SQL 파일(`V번호__설명.sql`)로만 바꾼다. 서버가 뜰 때 Flyway가 아직 적용하지 않은 파일을 번호 순으로 적용하고, JPA `ddl-auto`는 validate로 두어 엔티티와 DB가 다르면 서버가 뜨지 않게 한다. main에 merge된 파일은 고치거나 지우지 않고, 바꿀 것이 있으면 다음 번호 파일을 새로 추가한다. 테이블·컬럼을 바꿀 때는 이 저장소의 `erd_tables.sql`을 먼저 고친다 (OPS-08, 4.3 이중화 기술 7번) | 이미 적용된 파일을 고치면 Flyway가 기록과 달라진 것을 알아채 서버가 뜨지 않고, 팀원마다 DB 구조가 달라짐. 변경이 파일로 남아 어느 DB든 같은 순서로 같은 구조가 됨. 서버를 늘려도 한 번만 적용됨 | 4.3 이중화 기술 7번에 Flyway가 추천으로만 있었음 → 코드 저장소에 V1·V2를 만들며 1차부터 쓰기로 확정하고 규칙을 정함 |

| 번호 | 날짜 | 결정 (관련 항목) | 이유 | 이전 내용 → 바꾼 이유 |
|---|---|---|---|---|
| D-107 | 2026-10-07 | 메일 발송이 실패하면(Gmail 오류, 5초 시간 초과, 하루 발송 한도 초과) 화면에 "메일을 보내지 못했어요. 잠시 뒤 다시 시도해 주세요"를 띄운다. 서버가 자동으로 다시 보내지는 않고, 보내지 못한 인증번호는 바로 무효로 하며 1분 재발송 제한에 세지 않는다. 실패는 오류 로그에 남긴다. 안내 문구는 가입된 이메일인지와 상관없이 같다 (OPS-07, USR-02, USR-06, USR-08) | 다시 보내기 대기열은 1차 규모에 비해 구현이 커서 사용자가 직접 다시 누르게 함. 일반 Gmail 계정은 하루 약 500통까지라 한도에 가까워지면 메일 발송 서비스로 바꿈. 실패 안내가 이메일마다 다르면 가입 여부가 드러나므로 같게 함 (SC-003) | 메일이 실패했을 때의 처리가 없었음 → 시스템 요구사항 검토에서 추가 |
| D-106 | 2026-10-07 | 지원 브라우저는 Chrome과 Safari 최신 버전. PC는 Windows·Mac의 Chrome과 Mac Safari, 모바일은 Android Chrome과 iPhone Safari에서 확인한다. 다른 브라우저(Edge, Firefox, 삼성 인터넷 등)는 따로 확인하지 않는다 (OPS-06, 4.2) | 팀이 확인할 범위를 두 브라우저로 줄임. Edge와 삼성 인터넷은 Chrome과 같은 엔진이라 대부분 그대로 동작하지만 확인 대상에는 넣지 않음 | 반응형(PC·모바일)만 있고 어떤 브라우저인지 없었음 → 시스템 요구사항 검토에서 Chrome·Safari로 정함 |
| D-105 | 2026-10-07 | 자동 빌드·테스트: GitHub Actions가 PR과 main 브랜치 푸시마다 `./gradlew build` (코드 모양 검사, 테스트)를 돌리고, 통과해야 merge한다 (OPS-05) | 코드 모양이나 테스트가 깨진 코드가 main에 들어가는 것을 막음. 이중화 기술 8번(배포 자동화) 후보도 GitHub Actions라 같은 도구를 씀. 배포 자동화는 서버를 늘릴 때 정함 | 빌드·테스트를 언제 돌리는지 없었음 → 시스템 요구사항 검토에서 추가 |
| D-104 | 2026-10-07 | 서버 상태 확인 주소는 Spring Boot Actuator의 `/actuator/health` 하나만 연다. 누구나 볼 수 있지만 결과는 UP/DOWN만 보여 주고(DB 연결 포함), 세부 정보와 다른 Actuator 주소는 열지 않는다 (OPS-04, 4.3) | 서버를 2대 이상으로 늘리면 로드밸런서가 이 주소로 살아 있는 서버를 고름. 1차에도 배포 뒤 확인에 씀. 세부 정보(DB 종류, 디스크 등)는 공격에 쓰일 수 있어 숨김 | 서버가 살아 있는지 보는 방법이 없었음 → 시스템 요구사항 검토에서 추가 |
| D-103 | 2026-10-07 | 로그는 서버 파일에 날짜별로 남기고 30일 뒤 자동으로 지운다. 남길 것: 서버 오류(스택 트레이스, 오류 번호), 로그인 실패(가린 이메일, IP), 권한 거부(403: 회원 번호, 주소), 요청 제한 초과(429). 남기지 않을 것: 비밀번호, JWT·Refresh Token, 인증번호, 쿠키, CSRF 토큰. 이메일·전화번호는 4.4 방식으로 가려서 남긴다. 관리자 활동은 로그가 아니라 DB 기록(ADM-06, 1년)으로 남긴다 (OPS-03, 4.5) | 오류 원인과 공격 시도를 나중에 확인할 수 있게 함. 30일은 삭제 데이터 보관 기간(4.5)과 맞춤. 로그 파일이 새어도 비밀값과 개인 정보가 같이 새지 않게 함. 이중화 때는 CloudWatch로 모음(이중화 기술 10번) | 무엇을 로그로 남기는지 없었음 → 시스템 요구사항 검토에서 추가 |
| D-102 | 2026-10-07 | 오류가 나도 화면과 API 응답에 스택 트레이스, SQL, 클래스 이름, 서버 경로를 보이지 않는다. API 오류는 HTTP 상태와 같은 형식의 JSON(오류 코드, 안내 문구)으로 보내고, 화면 주소는 404·403·500 안내 화면(메인으로 가기 버튼)을 보여 준다. 500 오류에는 오류 번호를 함께 보여 주어 로그에서 찾을 수 있게 한다 (OPS-02) | 내부 정보가 보이면 공격자가 DB 구조와 쓰는 기술을 알 수 있음. 응답 형식이 같으면 공통 api.js 한 곳에서 오류를 처리할 수 있음 | 오류 응답 형식과 오류 화면이 없었음 → 시스템 요구사항 검토에서 추가 |

| 번호 | 날짜 | 결정 (관련 항목) | 이유 | 이전 내용 → 바꾼 이유 |
|---|---|---|---|---|
| D-101 | 2026-10-07 | DB는 매일 03:00(Asia/Seoul)에 전체 백업하고 7일치를 보관한다. 백업 파일은 서버 디스크가 고장나도 남도록 서버 밖 저장소에 복사하고 운영자만 열 수 있게 한다. 저장 위치는 배포 환경을 정할 때 고른다. 복구 절차를 문서로 두고 공개 전에 한 번 실제로 복구해 본다. 30일 뒤 지운 데이터도 백업에는 최대 7일 더 남는다 (OPS-01, 4.5) | DB가 망가지거나 실수로 지워져도 하루 전 데이터로 되살릴 수 있게 함. 03:00은 이용자가 적고 04:00 폐쇄·삭제 배치와 겹치지 않음. 백업에도 개인정보가 들어 있어 오래 두지 않음 | DB 백업·복구가 없었음 → 시스템 요구사항 검토에서 추가 |
| D-100 | 2026-10-07 | 블로그장이 계정 정지되면 그 사람이 블로그장인 블로그마다 "블로그장 정지 중" 공지를 띄우고, 정지 동안 블로그장은 블로그 관리 기능을 쓸 수 없음. 그 기간에 들어온 블로그 안 신고는 메인 관리자가 블로그장 대신 처리. 부블로그장은 신고 처리를 뺀 권한을 그대로 쓰고, 영구 정지는 블로그장 강퇴(ADM-07)와 같이 처리 (ADM-08, BLG-13) | 정지된 블로그장이 자기 블로그에서 제재를 피해 계속 운영하지 않게 하고, 멤버에게 상황을 알림. 신고가 처리되지 않고 쌓이는 것을 막음 | 계정 정지(D-99)를 넣으면서 블로그장이 정지된 경우를 정함 |
| D-99 | 2026-10-07 | 메인 프로필 신고의 처리 결과에 프로필 초기화(닉네임을 "회원"+회원 번호로, 사진·소개 삭제)와 계정 정지(3·14·30일·영구)를 추가. 정지된 회원은 로그인과 읽기만 되고 모든 블로그에서 글·댓글·좋아요·팔로우·구독·블로그 만들기·참여 신청을 못 함 (ADM-08, 3.7, ERD users.suspended_until, user_sanctions) | 문제 없음·경고만으로는 문제 있는 닉네임·사진을 고치거나 반복하는 회원을 막을 수 없음 | D-95 결과 "문제 없음 또는 경고" → 조치가 부족해 확대. D-44 "메인 관리자는 회원을 정지하지 않음" → 메인 프로필 신고에 한해 계정 정지 가능 |
| D-98 | 2026-10-07 | 태그 금칙어 항목을 없앰 (6.4) | 팀이 넣지 않기로 함 | 6.4에 "욕설 목록 단어는 태그 등록 불가"가 보류로 있었음 → 항목 삭제 |
| D-97 | 2026-10-07 | 블로그장 경고는 블로그별로 세고, 1년 지난 경고는 횟수에서 뺌. 최근 1년 안에 3번이면 권한 박탈 (ADM-07, 4.5) | 한 블로그의 문제로 다른 블로그의 블로그장 자격까지 잃지 않게 함. 경고 기록은 1년 보관(D-60) 뒤 지워지므로 보관 기간과 세는 기간을 같게 맞춤 | 경고 3번을 어떤 범위·기간으로 세는지 없었음 → 팀원 검토에서 나와 추가 |
| D-96 | 2026-10-07 | 메인 관리자의 블로그 강제 폐쇄도 누른 날짜 기준 7일 뒤 04:00에 폐쇄. 알림은 BLG-09와 같고, 7일 안에 그 블로그의 블로그장이 철회할 수 있음 (ADM-02, 7장) | 블로그장 폐쇄와 같은 04:00 배치·알림을 그대로 써서 구현이 늘지 않고, 멤버가 자기 글을 챙길 시간을 줌 | 강제 폐쇄가 즉시인지 7일 뒤인지, 철회는 누가 하는지 없었음 → 팀원 검토에서 나와 추가 |
| D-95 | 2026-10-07 | 메인 프로필에서 한 회원 신고는 메인 관리자가 처리. 결과는 문제 없음 또는 경고(대상에게 알림, 신고 기록으로 1년 보관). 회원 정지·탈퇴는 하지 않음 (SOC-06, ADM-04) | 메인 프로필은 어느 블로그에도 속하지 않아 처리할 블로그장이 없음. 정지는 블로그 단위라는 D-43, D-44와 맞춤 | 메인 프로필 신고를 누가 처리하는지 없었음 → 팀원 검토에서 나와 추가 |
| D-94 | 2026-10-07 | 블로그장에 대한 신고는 블로그장이 자기 블로그에 쓴 글·댓글 신고까지 메인 관리자가 처리 (SOC-06, ADM-04, BLG-13) | 블로그장이 자기에 대한 신고를 스스로 처리하지 않게 함 | 블로그 안의 글·댓글 신고는 모두 블로그장이 처리해 블로그장 본인 글이 빠져 있었음 → 팀원 검토에서 나와 추가 |

| 번호 | 날짜 | 결정 (관련 항목) | 이유 | 이전 내용 → 바꾼 이유 |
|---|---|---|---|---|
| D-93 | 2026-10-07 | 2장 권한표에서 메인 관리자의 "참여 승인·멤버 강퇴"를 X로 고침 (2장, ADM-01) | 메인 관리자는 블로그장 강퇴와 블로그 폐쇄만 한다는 D-44, ADM-01과 맞춤 | 권한표만 O로 남아 있었음 → 팀원 검토에서 나와 수정 |
| D-92 | 2026-10-07 | 글 본문은 최대 5,000자(공백·마크다운 기호 포함). DB 타입은 TEXT 유지 (6.6, ERD posts.content) | 보통 블로그 글은 1,000~3,000자라 1,000자는 사진 설명·마크다운 기호만 넣어도 부족하고, 500자는 더 짧음. 10,000자는 도배 글 하나가 너무 길어짐. TEXT(64KB)는 이모지만 써도 약 16,000자까지 들어가 5,000자에 충분하고, 제한을 바꿔도 DB를 고칠 필요가 없어 VARCHAR(5000) 대신 유지 | 최대 1,000자 → 길이가 부족해 5,000자로 늘림 |
| D-91 | 2026-10-06 | 만 14세 확인 체크는 두지 않음 (4.6) | 팀이 하지 않기로 함 | 4.6 "정할 것"에 추천안(체크박스로 가입 제한)으로 있었음 → 항목 삭제. 이유는 팀 확인 필요 |
| D-90 | 2026-10-06 | 관리자 계정은 블로그 활동(만들기·참여·글쓰기·댓글·좋아요·팔로우)을 하지 않음 (2장, SEC-09) | 관리자는 블로그를 관리하는 역할이라 활동과 관리를 나눔. 같은 users 테이블에서 role = ADMIN으로 구분하므로 별도 관리자 테이블은 두지 않음 | 2장 권한표에서 관리자도 블로그 생성·참여·글쓰기·팔로우가 O였음 → X로 변경 (글쓰기는 메인 공지만) |
| D-89 | 2026-10-06 | 인기순 기준: 블로그는 멤버 수, 글은 좋아요 수 (BLG-02, BRD-09) | 이미 저장하는 값(member_count, like_count)이라 따로 세지 않아도 되고 인덱스로 빠르게 정렬됨 | 인기순 기준이 없었음 → ERD 검증 중 빠진 것을 발견해 추가 |
| D-88 | 2026-10-06 | 블로그에도 태그를 단다 (BLG-01, 최대 10개, 6.4 규칙) | BLG-03의 태그 검색을 살리려면 태그를 넣는 곳이 필요함. 태그 검색을 빼는 안은 블로그를 찾기 어려워져 제외 | BLG-01에 태그 입력이 없어 BLG-03과 맞지 않았음 → 추가 |
| D-87 | 2026-10-06 | 대댓글은 답할 대상 회원을 comments.reply_to_user_id에 저장 (D-78, BRD-06) | 대댓글은 1단계라 부모가 첫 댓글로 고정돼 누구에게 답하는지 따로 저장해야 @닉네임을 표시할 수 있음. 본문에 글자로 넣으면 닉네임을 바꿨을 때 옛 이름이 남아 제외 | |

| 번호 | 날짜 | 결정 (관련 항목) | 이유 | 이전 내용 → 바꾼 이유 |
|---|---|---|---|---|
| D-86 | 2026-10-06 | 폐쇄된 블로그는 30일 뒤 내용만 지우고 블로그 행은 남김. 주소(slug)는 비워 재사용 (BLG-09, 4.5) | 제재·신고 기록(1년 보관)이 블로그를 FK로 가리켜 블로그 행을 지울 수 없음. FK를 비우는 안은 기록이 어느 블로그 것인지 알 수 없어 제외 | "폐쇄 블로그 완전 삭제" → 내용만 삭제로 변경 |
| D-85 | 2026-10-06 | 신고 대상은 target_type + target_id로 가리키고, 신고 당시 대상 내용을 target_snapshot에 저장 (SOC-06, 4.5, ERD reports) | 테이블이 단순하고 신고 대상 종류가 늘어도 ENUM 값만 추가하면 됨. 신고된 글·댓글은 30일 뒤 지워지지만 신고 기록은 1년 보관하므로, 내용을 같이 저장해야 분쟁 때 확인할 수 있음. 대상마다 FK 칸을 두는 방식은 칸이 늘 비고, 종류별 신고 테이블은 같은 코드가 반복돼 제외 | |
| D-84 | 2026-10-06 | DB 설계 시작: ERD 탭을 지금 요구사항 기준으로 다시 작성 (테이블 32개, ERDCloud용 표, 인덱스는 메모로 따로) | 요구사항이 금칙어(보류)와 이중화 기술 외에는 모두 확정돼 D-47의 조건(요구사항 정리 후)이 채워짐. 팀이 ERDCloud로 그리기로 해서 표로 정리하고, 조회용 인덱스는 쿼리가 정해진 뒤 추가하도록 메모로 분리 | 초기 요구사항 기준 ERD(테이블 20개)와 "나중에 갱신 예정" 목록 → 목록의 항목(이름·전화번호, 위임 요청, 블랙리스트, 제재 이력, 일부 공개, Refresh Token 등)을 모두 반영해 새로 작성 |
| D-83 | 2026-10-06 | 만료된 Refresh Token은 매일 새벽 4시 배치에서 지운다 (SEC-04, 4.5, BLG-09 폐쇄 처리) | 폐쇄 처리·완전 삭제를 하는 04:00 배치가 이미 있어 새 배치를 만들 필요가 없고, 이용자가 가장 적은 시간이라 DB 부담이 서비스에 영향을 주지 않음. ShedLock(SCL-03)으로 이중화 때도 한 번만 실행됨 | |
| D-82 | 2026-10-06 | Refresh Token은 DB(MySQL)에 저장한다 (SEC-04, USR-04, 4.3 로그인 토큰 저장) | 이미 쓰는 DB라 추가 비용이 없고, 서버를 늘려도 모든 서버가 같은 DB를 보므로 바꿀 것이 없음. 토큰을 새로 받을 때만 DB를 읽어 부담이 작음. Redis는 서버 1대인 1차에도 따로 띄워야 하고, 저장하지 않으면 로그아웃해도 토큰을 폐기할 수 없어 제외 | "DB나 Redis"로 미정 → 팀이 DB로 확정. 4.3의 세션 공유 비교표는 JWT 채택(D-53)으로 필요 없어져 로그인 토큰 저장 비교표로 바꿈 |

| 번호 | 날짜 | 결정 (관련 항목) | 이유 | 이전 내용 → 바꾼 이유 |
|---|---|---|---|---|
| D-81 | 2026-10-06 | 비밀번호 암호화는 bcrypt (7장, SEC-01) | Spring 기본이고 충분히 안전함. Argon2는 로그인마다 메모리를 많이 쓰고 라이브러리가 더 필요해 제외 | 추천안 → 팀이 확정 |
| D-80 | 2026-10-06 | 매크로 방지는 계정별 잠금 + IP별 요청 제한 (7장, SEC-03) | 여러 계정을 돌려 가며 시도하는 매크로도 막음. 계정별 잠금만 두면 남이 일부러 틀려 내 계정을 잠그거나 계정을 바꿔 시도하는 것을 못 막음 | 추천안 → 팀이 확정 |
| D-79 | 2026-10-06 | 사람 확인은 Cloudflare Turnstile (7장, SEC-13) | 무료이고 대부분 클릭 없이 통과해 편함. reCAPTCHA v2는 신호등 고르기 같은 문제가 번거롭고, 직접 만든 문자 이미지는 봇에 쉽게 뚫림 | 추천안 → 팀이 확정 |
| D-78 | 2026-10-06 | 대댓글은 1단계 + 답글 앞에 @닉네임 표시 (7장, BRD-06) | 팀이 원한 태그식이면서 화면은 1단계로 유지되고, 누구에게 답한 건지 보임. 깊이 제한 없는 방식은 화면이 오른쪽으로 밀려 제외 | 추천안 → 팀이 확정 |
| D-77 | 2026-10-06 | 조회수는 DB 조회 기록 테이블로 셈 (7장, BRD-11) | 같은 사람 하루 1번 규칙을 정확히 지킬 수 있음. 쿠키 방식은 쿠키를 지우면 다시 세서 뷰봇을 못 막고, Redis는 서버를 따로 띄워야 해 제외 | 추천안 → 팀이 확정 |
| D-76 | 2026-10-06 | 목록은 번호 페이지 (7장, BRD-02) | 확정된 10·20·30개 선택과 맞고 원하는 페이지로 바로 갈 수 있음. 더보기·무한 스크롤은 개수 선택과 안 맞고 보던 위치로 돌아가기 어려워 제외 | 추천안 → 팀이 확정 |
| D-75 | 2026-10-06 | 이미지는 1차에 서버 디스크에 저장, 이중화 때 S3로 (7장, BRD-05) | 추가 설정과 비용이 없고 지금 코드 방식 그대로임. FileStorage 인터페이스(SCL-02)로 나눠 두면 나중에 S3로 쉽게 바꿈 | 추천안 → 팀이 확정 |
| D-74 | 2026-10-06 | 에디터는 Toast UI Editor (7장, BRD-01) | 한국어 에디터이고 입력·미리보기·툴바·이미지 업로드 연결이 다 들어 있음. EasyMDE는 이미지 업로드를 직접 연결해야 하고, 직접 만들기는 툴바·미리보기를 모두 만들어야 해 제외 | 추천안 → 팀이 확정 |

| 번호 | 날짜 | 결정 (관련 항목) | 이유 | 이전 내용 → 바꾼 이유 |
|---|---|---|---|---|
| D-73 | 2026-10-06 | 메인 피드는 볼 때마다 모아오기 (7장, BRD-09) | 테이블 추가가 없고 글 삭제·차단·비공개 전환이 바로 반영됨. 글 쓸 때 미리 넣는 방식은 피드 테이블과 정리 작업이 복잡해 제외. 성능 목표(4.2)를 넘기면 다시 검토 | 추천안 → 팀이 확정 |
| D-72 | 2026-10-06 | 알림은 30초마다 확인(폴링) (7장, SOC-04) | 일반 API로 끝나 구현이 가장 쉽고 이중화에도 문제가 없음. SSE·WebSocket은 연결을 계속 유지해 서버 자원을 쓰고, 서버가 여러 대면 서버끼리 알림을 주고받는 장치가 필요해 제외 | 추천안 → 팀이 확정 |
| D-71 | 2026-10-06 | 부블로그장 권한은 권한별 체크박스로 설정 (7장) | 블로그장이 범위를 정한다는 팀 결정(D-03)과 그대로 맞음. 미리 정한 등급 중 고르는 방식은 세밀하게 고를 수 없어 제외 | 추천안 → 팀이 확정 |
| D-70 | 2026-10-06 | 블로그 주소는 경로 방식 /blog/{주소} (7장, BLG-01) | 도메인 하나로 끝나고 로그인 쿠키가 그대로 공유되며 로컬 개발이 쉬움. 서브도메인은 와일드카드 DNS·인증서·쿠키 도메인 설정이 필요해 제외 | 추천안 → 팀이 확정 |
| D-69 | 2026-10-06 | 메일 발송은 Gmail SMTP (7장, USR-02, USR-06, USR-08) | 무료이고 Spring Mail 설정 몇 줄이면 됨. 메일 발송 서비스(AWS SES 등)는 가입과 도메인 인증이 필요하고 일정량을 넘으면 유료라, 사용자가 늘면 교체함 | 추천안 → 팀이 확정 |
| D-68 | 2026-10-06 | 블로그 개수 제한값은 설정 파일에 두고 환경변수로 덮어씀. 만들 때는 개수 확인과 생성을 DB에서 잠금 (7장 개수 제한값, BLG-10) | 개수를 자주 바꿀 일이 없어 설정 파일이면 충분함. 환경변수로 두면 서버가 여러 대여도 한 곳에서 같은 값을 적용할 수 있음. 동시에 두 번 누르면 두 요청이 모두 개수 확인을 통과해 제한을 넘을 수 있어 DB 잠금으로 막음 | 추천안 "설정 파일"에 이중화 대비(환경변수)와 동시 생성 방지(DB 잠금)를 더해 확정 |
| D-67 | 2026-10-06 | 폐쇄 예정 7일 동안 블로그는 평소처럼 운영 (7장 폐쇄 예정 중 상태, BLG-09) | 폐쇄 버튼을 누르면 즉시·3일 전·1일 전에 공지와 알림이 가서 멤버가 미리 챙길 수 있고, 철회도 가능해 읽기 전용으로 막을 필요가 없음. 추가 구현도 없음 | 추천안 "읽기 전용" → 평소처럼 운영 선택 |

| 번호 | 날짜 | 결정 (관련 항목) | 이유 | 이전 내용 → 바꾼 이유 |
|---|---|---|---|---|
| D-66 | 2026-10-06 | 화면은 정적 HTML + JS(화면과 API를 나눠 개발). 글 상세는 SNS 미리보기를 위해 서버가 og 태그만 채움 (7장 화면 방식, SEC-10) | 화면과 서버(API)를 나눠 개발할 수 있고 팀이 익숙한 방식 (팀 확인 필요). 글 본문은 서버가 걸러서 보내므로 XSS 방어(D-64)는 그대로 유지됨 | 전부 Thymeleaf(D-63) → 팀 논의 후 HTML + JS로 변경 |
| D-65 | 2026-10-06 | 메인 피드에서 팔로우한 회원의 글과 구독한 블로그의 글은 탭을 나눠 보여줌 (7장 메인 피드, BRD-09) | 글이 어디서 왔는지 분명하고, 한 목록에 섞을 때 필요한 중복 제거가 필요 없음 | 추천안 "하나로 합치기" → 탭 나누기 선택 |
| D-64 | 2026-10-06 | XSS는 서버에서 걸러냄(jsoup). 화면에서는 사용자 입력을 이스케이프(th:text, textContent)하고 CSP로 한 번 더 막음 (7장 XSS 걸러내는 위치, SEC-06, SEC-12) | 서버에서 걸러야 API를 직접 부르는 공격도 막힘. 화면을 모두 서버에서 만들기로 해서(D-63) 마크다운 변환과 걸러내기를 서버 한 곳에서 할 수 있음. HttpOnly(D-53)는 토큰 탈취만 막고 XSS 자체는 못 막으므로 실행을 막는 방어가 따로 필요함 | 추천안 → 팀이 확정 |
| D-63 | 2026-10-06 | 화면은 전부 Thymeleaf(서버가 HTML을 만듦)로, 일부 기능만 JS 요청 (7장 화면 방식, SEC-10) | 기존 화면을 어차피 새로 만들어야 해서 섞어 쓸 이유가 없음. 한 방식으로 통일하면 규칙이 단순하고, SNS 미리보기(og 태그)·XSS 방어·CSRF 토큰을 서버에서 한 번에 처리함 | 추천안 "대부분 정적 + 글 상세만 Thymeleaf" → 새로 만드는 상황이라 전부 Thymeleaf로 |
| D-62 | 2026-10-06 | 로그인 30분 연장 기준: 직접 한 행동으로 간 요청만 활동으로 셈. 알림 자동 확인·스크롤은 제외, 글쓰기 중 입력은 연장, 만료 5분 전 연장 안내 (SEC-04) | 알림 자동 확인까지 세면 탭만 열어 두어도 로그아웃되지 않아 "나가면 로그아웃"이 의미가 없어짐. 글을 오래 쓰는 중에는 서버 요청이 없어 저장하는 순간 로그아웃될 수 있어 입력 중 연장과 만료 전 안내를 둠 | |
| D-61 | 2026-10-06 | "로그인 유지" 체크박스: 체크 안 하면 브라우저를 닫거나 30분 무활동 시 로그아웃, 체크하면 14일 유지 (SEC-04, USR-03) | 화면을 나가면 로그아웃되는 것을 기본으로 해 공용 PC에서 로그인이 남지 않게 하고, 자기 기기에서는 체크해서 편하게 씀. 탭을 닫는 순간 로그아웃하는 방식은 새로고침·페이지 이동에도 로그아웃되고 모바일에서 잘 동작하지 않아 제외 | 6.7 "세션 1시간, 요청하면 연장"(세션 방식) → JWT로 바꾼 뒤(D-53) 로그인 유지 방식으로 다시 정함 |

| 번호 | 날짜 | 결정 (관련 항목) | 이유 | 이전 내용 → 바꾼 이유 |
|---|---|---|---|---|
| D-60 | 2026-10-06 | 운영 기록(관리자 활동·신고·경고·정지)은 30일이 아니라 1년 보관 (4.5) | 정지 3번·경고 3번처럼 이력을 세야 하고, 분쟁이 생기면 확인해야 함 | 추천안 → 채택 |
| D-59 | 2026-10-06 | 공유 미리보기 대표 이미지는 글의 첫 이미지를 줄여서, 없으면 블로그 대표 이미지를 줄여서. 미리보기는 주소 → 제목 → 이미지 순서 (BRD-07) | 어떤 글이든 미리보기에 이미지가 들어가 눈에 띄고, 보여주는 순서를 정해 두어야 화면을 만들 때 기준이 명확함 | 6.2 대표 이미지 보류 → 팀 회의에서 확정 |
| D-58 | 2026-10-06 | 블로그장도 자기 블로그의 다른 멤버 글을 삭제할 수 있음, 수정은 불가 (BRD-01) | 메인 관리자가 모든 블로그를 살피기 어려워 블로그장이 문제 글을 바로 내려야 함. 수정을 막는 이유는 관리자와 같음(D-07) | 6.6 추천안 → 채택 |
| D-57 | 2026-10-06 | 정지 기간 선택지(3일·14일·30일·영구)는 메인 관리자와 블로그장이 같이 쓰고, 둘의 제재 권한 차이는 표 하나로 정리 (3.7) | 누가 제재하든 같은 기준이어야 사용자에게 일관되고, 규칙이 여러 곳에 흩어지지 않음 | 6.7 "회원 정지 기간"(메인 관리자용 추천안) → 정지가 블로그 단위로 바뀌어(D-43) 공통 규칙으로 옮김 |
| D-56 | 2026-10-06 | 알림 탭과 끌 수 있는 알림 확정. 참여 승인·거절 알림도 끌 수 있게 하고, 읽은 알림은 강조 색이 사라짐 (3.6) | 읽음 여부가 색으로 구분되고 사람마다 원하는 알림이 달라, 끌 수 있는 범위를 팀에서 조정함 | 끌 수 없는 알림·탭 구성 추천안 → 팀이 수정해 확정 |
| D-55 | 2026-10-06 | 블랙리스트 기록은 블로그 안에 보관하고, 블로그장이 바뀌면 새 블로그장·부블로그장은 열람만 가능 (BLG-11, 4.5) | 블로그장이 바뀌어도 왜 막았는지 알 수 있어야 하고, 새 블로그장이 기록을 임의로 지우면 블랙리스트의 의미가 없어짐 | |
| D-54 | 2026-10-06 | 권한을 박탈당한 블로그장은 일반 멤버로 남고, 새 블로그장이 멤버 유지·정지·강제 퇴장을 판단 (ADM-07) | 블로그 사정은 그 블로그를 맡은 사람이 가장 잘 알고, 메인 관리자는 멤버를 관리하지 않음 (D-43, D-44) | |
| D-53 | 2026-10-06 | 로그인은 JWT로 하고 토큰은 HttpOnly 쿠키에 담음 (SEC-04, 4.1 아래 팀 결정) | 서버 이중화를 대비해 서버끼리 로그인 정보를 공유하지 않아도 되게 함. HttpOnly 쿠키라 JS가 토큰을 읽을 수 없어 XSS 탈취를 막음 | 세션 + 쿠키(D-11) → 이중화 때 Spring Session + Redis가 필요해서, 미리 대비하기 위해 변경 |
| D-52 | 2026-10-06 | 블로그 생성 개수 확정: 공개(일부 공개 포함) 3개, 비공개 5개. 공개 개수는 설정값으로 5개까지 늘릴 수 있음 (BLG-10) | 팀에서 정한 범위(공개 3~5개, D-04) 안에서 작게 시작하고, 사용자가 늘면 설정값만 바꿔 늘림 | BLG-10 비고 "개수 미정" → 6.7 추천안을 채택해 확정 |

| 번호 | 날짜 | 결정 (관련 항목) | 이유 | 이전 내용 → 바꾼 이유 |
|---|---|---|---|---|
| D-51 | 2026-10-06 | 일부 공개 블로그는 공개 블로그 개수(3개)에 포함 (BLG-10) | 링크만 있으면 외부 사람도 볼 수 있어 성격이 공개 블로그에 가까움. 비공개 개수로 세면 공개 제한을 우회할 수 있음 | |
| D-50 | 2026-10-06 | 일부 공개 블로그는 링크로 들어온 비회원도 볼 수 있고, 자동 구독 대신 "구독하기" 버튼을 보여줌 (BLG-01) | 링크를 받은 사람이 가입하지 않아도 볼 수 있어야 링크 공유의 의미가 있음. 자동 구독은 한 번 눌렀을 뿐인데 원치 않는 구독과 알림이 생기고 비회원은 구독할 수도 없음. 구독하면 링크 없이 다시 들어올 수 있음 | |
| D-49 | 2026-10-06 | 블로그 공개 범위를 공개·일부 공개·비공개 3단계로. 일부 공개는 공유 링크로만 들어감, 비공개는 링크 없이 멤버만 (BLG-01) | 멤버가 아닌 사람에게 링크로 보여주는 기능과 진짜 비공개를 둘 다 제공함. 블로그 주소는 추측할 수 있어서 공유 링크에는 무작위 값을 넣음 | 공개·비공개 2단계, 6.2에 "URL을 주면 보이게"와 "권한 없는 사람은 못 봄"이 충돌 → 3단계로 나눠 해결 (당시 비공개 범위 추천안 채택) |
| D-48 | 2026-10-06 | 성능 목표: 메인·목록·검색은 1~2초 안에 응답(목표 1초, 늦어도 2초), 5초를 넘기면 중단하고 안내 (4.2) | 사용자가 기다린다고 느끼지 않는 수준을 숫자로 정해야 개발·테스트에서 확인할 수 있음. 5초 제한은 무한 로딩을 막기 위한 팀 의견(6.1) | "목표 응답 시간은 팀에서 정한다" → 숫자로 확정 |
| D-47 | 2026-10-06 | DB 설계(ERD)는 요구사항 정리가 끝난 뒤 나중에 함 (DB 설계 탭) | 요구사항이 아직 바뀌고 있어, 지금 DB를 고치면 다시 고치는 일이 많아짐. 반영할 목록은 DB 설계 탭 맨 위에 적어 둠 | |
| D-46 | 2026-10-06 | 신고 누적은 블로그 안에서만: 블로그장이 신고를 보고 정지를 주고, 정지가 3번 쌓이면 블로그장이 그 블로그에서 강제 퇴장 (BLG-13) | 신고 횟수가 아니라 블로그장이 신고를 보고 준 정지 횟수를 세므로, 멤버 몇 명이 짜고 허위 신고를 해도 바로 쓸려나지 않음. 메인 계정은 그대로라 메인 관리자 권한 축소(D-44)와도 맞음 | "정지 3번이면 강제 탈퇴(수동)" → 사이트 전체 탈퇴로 읽혀서, 블로그 안의 정지 3번과 강제 퇴장으로 명확히 함 |
| D-45 | 2026-10-02 | 블로그 안의 신고는 블로그장이, 블로그·블로그장에 대한 신고는 메인 관리자가 처리 (SOC-06, ADM-04, BLG-13) | 신고 처리 결과(경고·정지·강제 퇴장)는 메인 관리자와 블로그장 모두에게 필요한 권한이므로, 각자 자기 범위의 신고를 처리함 | 모든 신고를 메인 관리자가 처리 → D-43에 맞춰 범위별로 나눔 |

| 번호 | 날짜 | 결정 (관련 항목) | 이유 | 이전 내용 → 바꾼 이유 |
|---|---|---|---|---|
| D-44 | 2026-10-02 | 메인 관리자는 블로그장 강퇴(권한 박탈)와 블로그 폐쇄만 함 (ADM-01, ADM-07) | 메인 관리자가 모든 블로그의 모든 멤버를 관리하기는 어렵기 때문에, 블로그를 책임지는 블로그장만 관리함 | 메인 관리자가 회원 정지·강제 탈퇴 → 관리 부담이 커서 블로그장 단위 관리로 변경 |
| D-43 | 2026-10-02 | 멤버 경고·정지·강제 퇴장은 블로그 단위로 블로그장이 함. 정지되면 그 블로그에만 못 들어감 (BLG-13) | 블로그 사정은 블로그장이 가장 잘 알고, 한 블로그의 문제로 다른 블로그 활동까지 막을 이유가 없음 | D-29 "정지되면 모든 개별 블로그 입장 불가"(메인 관리자가 정지) → 블로그 단위 정지로 변경 |
| D-42 | 2026-10-02 | 가입 이메일 인증번호 만료를 10분으로 (USR-02, 6.7) | 가입 화면에서 바로 입력하는 번호라 길 필요가 없고, 짧을수록 번호를 마구 넣어 맞추는 공격에 안전함 | 2시간 → 인증 방식이 링크에서 가입 중 바로 입력하는 번호로 바뀌어 짧게 조정 |
| D-41 | 2026-10-02 | 개인정보 처리 규칙 추가: 수집 항목·목적·동의·보관 (6.11) | 이름과 전화번호를 받으므로 동의 절차가 필요하고, 무엇을 왜 받는지 한곳에 정리해 안 쓰는 정보를 받지 않기 위해 | |
| D-40 | 2026-10-02 | 삭제·탈퇴·폐쇄된 데이터는 전체적으로 30일 보관 후 삭제 (6.10) | 실수나 분쟁에 대비할 여유를 두되, 기간을 하나로 통일해 규칙과 배치를 단순하게 함 | |
| D-39 | 2026-10-02 | 알림은 종 아이콘 → 사이드바 탭, 내 정보에서 체크박스로 종류별 켜기·끄기 (SOC-04, 6.9) | 알림 종류가 많아 한 목록에 섞이면 찾기 어렵고, 사람마다 원하는 알림이 다름 | |
| D-38 | 2026-10-02 | 신고 처리 결과는 문제 없음, 경고, 정지(해제 가능), 강제 퇴장 (ADM-04) | 처리 결과를 정해 두어야 관리자마다 다르게 처리하지 않고 알림 문구도 만들 수 있음 | |
| D-37 | 2026-10-02 | 비공개로 바꾸면 구독은 유지, 멤버 아닌 구독자는 글이 안 보이고 알림을 받음 (BLG-01) | 다시 공개로 바뀌면 구독자가 그대로 이어서 볼 수 있고, 글이 갑자기 안 보여도 이유를 알 수 있음 | |
| D-36 | 2026-10-02 | 차단해도 같은 블로그 안에서는 글이 보임. 블로그장이 차단한 회원의 참여 신청은 자동 거절 (SOC-05) | 개인 차단이 블로그 운영(글 관리·신고 처리)을 막지 않게 하고, 블로그장이 피하려는 사람이 들어오는 것은 막음 | |
| D-35 | 2026-10-02 | 폐쇄된 블로그의 글은 30일 보관 후 삭제, 주소는 30일 뒤 재사용 (BLG-09) | 분쟁이나 복구 요청에 대비하고, 좋은 주소가 영원히 묶이는 것을 막음 | |

| 번호 | 날짜 | 결정 (관련 항목) | 이유 | 이전 내용 → 바꾼 이유 |
|---|---|---|---|---|
| D-34 | 2026-10-02 | 강퇴한 멤버는 이름·이메일·전화번호로 블랙리스트, 해제는 문의하기 → 블로그장이 직접 확인 (BLG-11, BLG-12) | 탈퇴 후 재가입으로 다시 들어오는 것을 막고, 전화번호 주인이 바뀐 사람은 구제할 길을 둠. 블랙리스트는 해시로 보관해 개인정보 노출을 줄임 | |
| D-33 | 2026-10-02 | 블로그를 떠나거나 강퇴된 멤버의 글은 "탈퇴한 계정"으로 표시 (BLG-07, BLG-11) | 글과 댓글의 맥락은 남기되, 떠난 사람의 정보가 그 블로그에 계속 연결되지 않게 함 | 추천안 "작성자 그대로 표시" → 떠난 사람과 블로그의 연결을 끊기 위해 변경 |
| D-32 | 2026-10-02 | 이름은 바꿀 수 없고 전화번호만 본인이 수정 (USR-07) | 이름은 이메일 찾기와 블랙리스트 본인 확인의 기준이라 고정하고, 전화번호는 실제로 바뀔 수 있어 수정을 허용 | |
| D-31 | 2026-10-02 | 위임 요청은 7일 안에 응답이 없으면 자동 취소 (BLG-08) | 요청이 끝없이 대기하면 블로그장이 다른 멤버에게 요청하거나 폐쇄할 수 없음 | |
| D-30 | 2026-10-02 | 블로그장 경고 3회 누적 시 권한 박탈, 부블로그장에게 이전 또는 7일 유예 후 폐쇄 (ADM-07) | 블로그장 한 사람의 문제로 블로그 전체를 바로 닫지 않고, 단계적으로 처리해 멤버의 피해를 줄임 | 추천안 "정지 동안 블로그장 기능만 막기" → 경고 누적 방식으로 변경 |
| D-29 | 2026-10-02 | 정지된 회원은 로그인만 되고 개별 블로그에는 들어갈 수 없음 (ADM-01) | 정지 기간과 사유는 확인할 수 있게 하되, 활동 공간인 블로그는 막음 | 추천안 "로그인·읽기 가능, 쓰기만 막기" → 블로그 입장 자체를 막도록 변경 |
| D-28 | 2026-10-02 | 가입 화면도 가입 여부를 드러내지 않음 (USR-02) | 비밀번호 찾기와 같은 방식으로 맞춰야 가입자 목록을 모으는 공격을 막을 수 있음 | 이미 가입된 이메일이면 인증번호를 보내지 않음 → 가입 여부가 드러나서 변경 |
| D-27 | 2026-10-02 | "아이디 찾기"를 "이메일 찾기"로 이름 변경 (USR-08) | 이메일이 곧 아이디라, 무엇을 찾는지 바로 알 수 있는 이름이 사용자에게 더 정확함 | 아이디(이메일) 찾기 → "아이디"라는 말이 따로 있는 것처럼 보여 헷갈려서 |
| D-26 | 2026-10-02 | 이메일 찾기 결과에서 비밀번호 재설정까지 이어짐. 재설정 요청은 임시 토큰(10분)으로 함 (USR-08) | 이메일과 비밀번호를 모두 잊어도 한 흐름으로 해결됨. 바꾸기 직전에 이메일 인증을 거치므로 이름·전화번호만 아는 사람은 바꿀 수 없음. 회원 번호를 넘기면 번호만 바꿔 남에게 인증 메일을 보낼 수 있어 토큰을 씀 | 가린 이메일만 보여줌 → 두 가지를 다 잊은 사람이 다시 비밀번호 찾기로 가야 해서 연결 |

| 번호 | 날짜 | 결정 (관련 항목) | 이유 | 이전 내용 → 바꾼 이유 |
|---|---|---|---|---|
| D-25 | 2026-10-02 | 비밀번호 재설정을 6자리 인증번호로 (USR-06, 6.7) | 가입과 같은 방식이라 코드를 재사용하고, 화면을 벗어나지 않고 새 비밀번호까지 이어짐 | 재설정 링크 → 메일 앱에서 새 창이 열려 흐름이 끊기고 이메일 찾기(D-26)와 연결하기 어려워서 |
| D-24 | 2026-10-02 | 전화번호는 1차에 중복 허용 (6.5) | 문자 인증 없이 중복을 막으면 누군가 내 번호로 먼저 가입했을 때 나는 가입할 수 없음. 문자 인증을 넣는 2차에 한 번호 한 계정으로 바꿈 | |
| D-23 | 2026-10-02 | 이메일 찾기는 이름 + 전화번호, 결과는 가려서 표시 (USR-08) | 무료이고 구현이 간단함. 결과를 가려 보여주니 위험이 작음. 문자 인증은 비용과 API 키가 필요해 2차로 미룸 | |
| D-22 | 2026-10-02 | 개인정보를 보는 사람에 따라 가려서 표시, 비밀번호 칸은 없음 (6.8) | 블로그장 등에게는 운영에 필요한 만큼만 보여줌. 화면에서만 가리면 API 응답에 원래 값이 남아 서버에서 가림 | |
| D-21 | 2026-10-02 | 이메일은 바꿀 수 없음 (USR-07) | 이메일이 아이디라, 바뀌면 로그인과 이메일 찾기의 기준이 흔들림 | |
| D-20 | 2026-10-02 | 폐쇄 예정 중에는 위임 불가, 철회해야 위임 가능 (BLG-08) | 곧 닫힐 블로그를 다른 사람이 넘겨받는 상황을 막음 | |
| D-19 | 2026-10-02 | 폐쇄 철회 버튼 (BLG-09) | 실수로 누르거나 마음이 바뀌어도 7일 안에 되돌릴 수 있게 | |
| D-18 | 2026-10-02 | 폐쇄 예정 중에는 블로그장 탈퇴 불가 (USR-05) | 철회할 수 있는 7일 동안은 블로그장이 남아 있어야 함 | 추천안 "탈퇴 허용" → 철회 기능(D-19)과 맞추려고 "막기"를 선택 |
| D-17 | 2026-10-02 | 관리자가 블로그장을 강제 탈퇴시키면 부블로그장에게 자동 위임, 없으면 7일 뒤 폐쇄 (ADM-01) | 본인이 위임이나 폐쇄를 할 수 없는 예외 상황이라 따로 규칙이 필요함 | |
| D-16 | 2026-10-02 | 위임은 받는 멤버가 수락·거절 (BLG-08) | 원하지 않는 사람에게 블로그장을 떠넘기는 것을 막음 | |
| D-15 | 2026-10-02 | 블로그장은 위임이나 폐쇄를 끝낸 뒤에만 탈퇴 (USR-05) | 주인 없는 블로그가 생기지 않고, 탈퇴 로직이 단순해지며, 블로그장이 직접 정리 방법을 고름 | 위임 없이 탈퇴하면 7일 뒤 자동 폐쇄 → 그 7일 동안 신고·참여 신청을 처리할 블로그장이 없어서 |

| 번호 | 날짜 | 결정 (관련 항목) | 이유 | 이전 내용 → 바꾼 이유 |
|---|---|---|---|---|
| D-14 | 2026-10-02 | 폐쇄 알림은 블로그장을 제외한 그 블로그 멤버와 구독자에게 (BLG-09) | 그 블로그 글을 보는 사람만 알면 됨 | 멤버만, 구독자 제외 → 구독자도 그 블로그를 보는 사람이라 포함. 다른 블로그 멤버는 관계없어 제외 |
| D-13 | 2026-10-02 | 폐쇄 알림은 버튼을 누른 즉시, 3일 전, 1일 전 (BLG-09) | 멤버가 자기 글을 챙길 시간을 줌 | |
| D-12 | 2026-10-02 | 폐쇄는 버튼을 누른 날짜 기준 7일 뒤 새벽 4시, `@Scheduled`로 처리 (7장 폐쇄 처리) | 이용자가 가장 적은 시간이고, "며칠 몇 시에 닫힌다"고 정확히 안내할 수 있음 | "블로그장이 탈퇴하면 7일 뒤" → D-15로 탈퇴 대신 폐쇄 버튼 기준이 됨 |
| D-11 | 2026-10-02 | 로그인은 세션 + 쿠키 (당시 로그인 방식, 이후 D-53으로 변경) | 로그아웃·정지가 즉시 반영되고 Spring Security와 맞물림. JWT는 즉시 무효화에 블랙리스트, 연장에 Refresh Token이 필요하고 이중화 장점은 Spring Session + Redis로도 얻을 수 있음 | |
| D-10 | 2026-10-02 | 이메일 인증은 6자리 인증번호, Spring에서 직접 발송·검증 (USR-02, 7장 이메일 인증) | 가입 화면을 벗어나지 않고, 외부 서비스 없이 규칙을 직접 정할 수 있음 | 가입 후 인증 링크 → 가입 전에 인증하는 흐름(D-08)에 맞춰 변경 |
| D-09 | 2026-10-02 | 보안은 Spring Security (보안 헤더, CSRF 토큰, 인증·인가) (7장 보안 프레임워크, SEC-10~12) | 보안 중심이라는 팀 방향에 맞게 검증된 방어가 기본 제공됨. 직접 만들면 하나만 빠뜨려도 구멍이 생김 | |
| D-08 | 2026-10-02 | 이메일을 아이디로 씀. 이메일 인증 → 비밀번호 → 이름·닉네임·전화번호 순서로 가입 (USR-01) | 아이디를 따로 외울 필요가 없고, 인증된 이메일만 계정이 됨 | 이메일·비밀번호·닉네임만 받음 (기존 코드는 아이디를 따로 받음) → 팀 회의에서 가입 절차를 정하며 변경 |
| D-07 | 2026-10-02 | 글 수정은 작성자만, 삭제는 작성자와 관리자 (BRD-01) | 관리자가 고칠 수 있으면 작성자가 쓰지 않은 내용이 작성자 이름으로 남을 수 있음. 문제 글은 관리자가 빨리 내려야 함 | 수정·삭제 모두 작성자와 관리자 → 관리자의 내용 조작을 막기 위해 |
| D-06 | 2026-10-02 | 목록은 한 페이지에 10·20·30개 중 선택 (BRD-02) | 화면 크기와 취향에 맞게 사용자가 고름 | |
| D-05 | 2026-10-02 | 탈퇴한 회원의 글은 "탈퇴한 회원"으로 남김 (6.7) | 글을 지우면 다른 사람의 댓글과 대화 맥락이 깨짐 | |

| 번호 | 날짜 | 결정 (관련 항목) | 이유 | 이전 내용 → 바꾼 이유 |
|---|---|---|---|---|
| D-04 | 2026-10-02 | 공개 블로그 회원당 3개(설정값), 비공개 5개 (BLG-10, 6.7) | 블로그를 마구 만들고 방치하는 것을 막음 (팀 합의) | 비공개 제한 없음(5장) → 5개로 변경. 비공개 블로그가 너무 많으면 데이터가 늘어나고, 한 사람에게 그렇게 많이 필요하지 않다고 팀에서 판단 |
| D-03 | 2026-10-02 | 부블로그장을 두고 블로그장이 권한 범위를 설정 (5장, 7장 부블로그장 권한) | 블로그장 혼자 운영하기 어렵고, 블로그마다 맡길 일이 다름 (팀 합의) | |
| D-02 | 2026-10-02 | 회원 팔로우와 블로그 구독을 둘 다 둠 (SOC-01) | 사람을 따라가는 것과 블로그를 따라가는 것은 목적이 다름 (팀 합의) | |
| D-01 | 2026-10-02 | 참여 방식(자유/승인제)은 블로그장이 고름 (BLG-04) | 블로그마다 성격이 달라 운영하는 사람이 정하는 게 맞음 (팀 합의) | |